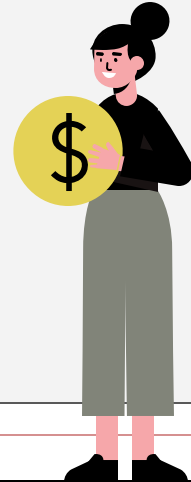




Sécurisation des transactions bancaires par signatures numériques via courbes elliptiques (ECDSA)



L'équipe

2



Guy-Charbel
KAIROUZ



Thomas LEROY



Jordana Raïane
NKOMBA



Parfait-Junior
MONEZE

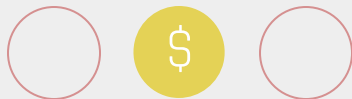
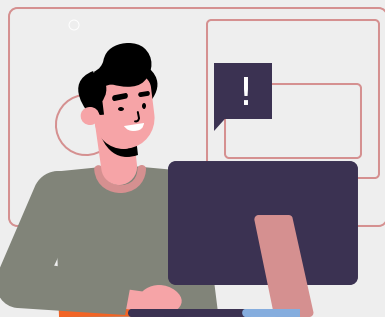


TABLE DES MATIÈRES



01

Introduction

02

Contexte et état de l'art

03

Notre organisation

04

ECDSA : comment ça marche ?

05

Problèmes et solutions

06

Démonstration

La cryptographie

4

Applications of cryptography

Computer
Passwords



Digital
Currencies



Secure Web
Browsing



Electronic
Signatures



Authentication



Cryptocurrencies



End-to-end Internet
Encryption

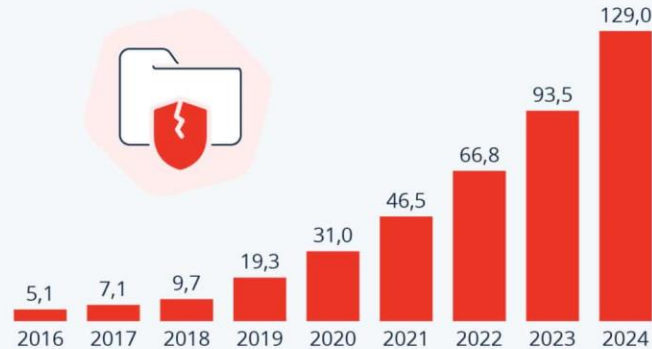


Un enjeu actuel

5

Le coût des cyberattaques explose en France

Estimation du coût annuel de la cybercriminalité en France, en milliards de dollars américains

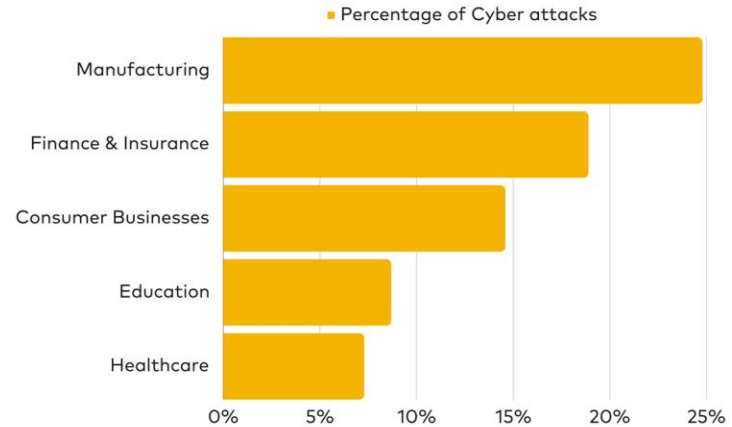


Source : Statista Technology Market Insights



statista

MOST ATTACKED INDUSTRIES

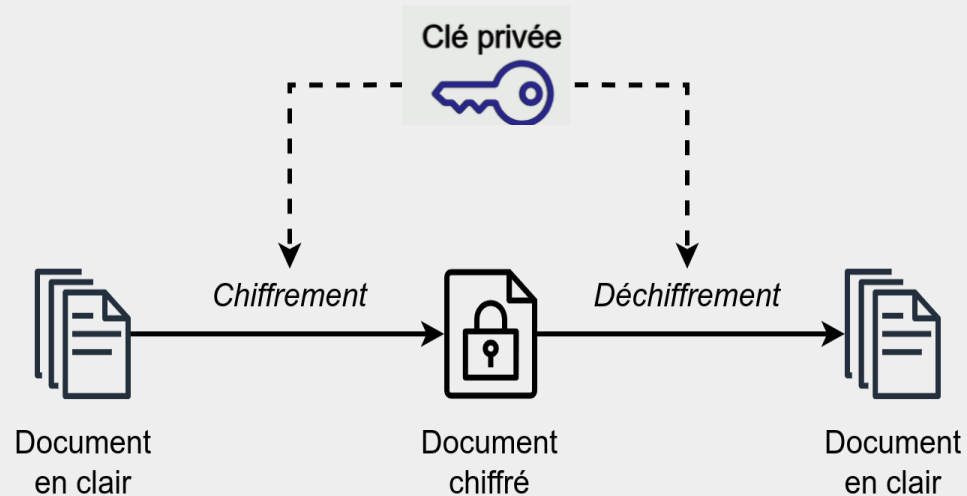


astra

Les types d'algorithmes

6

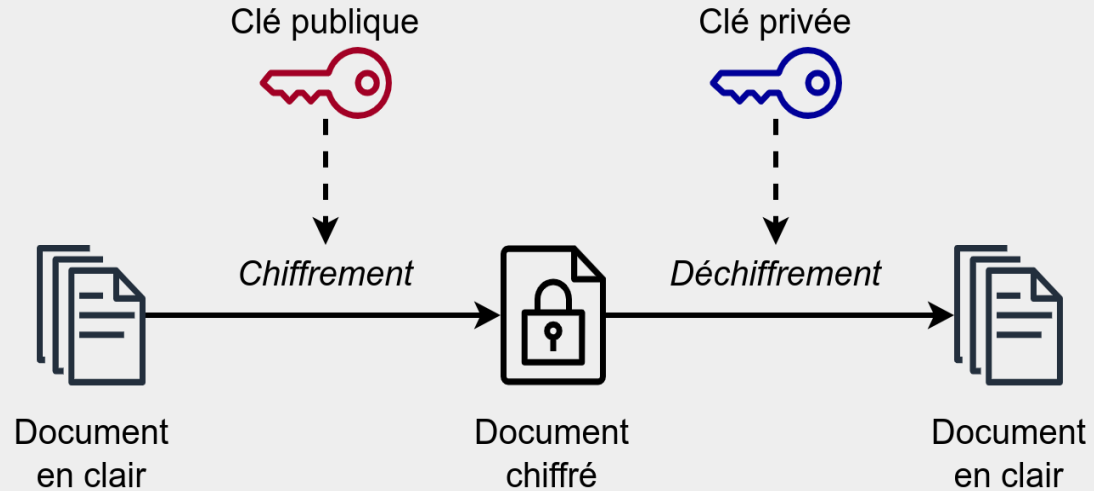
1/ Symétrique :



Les types d'algorithmes

7

2/ Asymétrique :

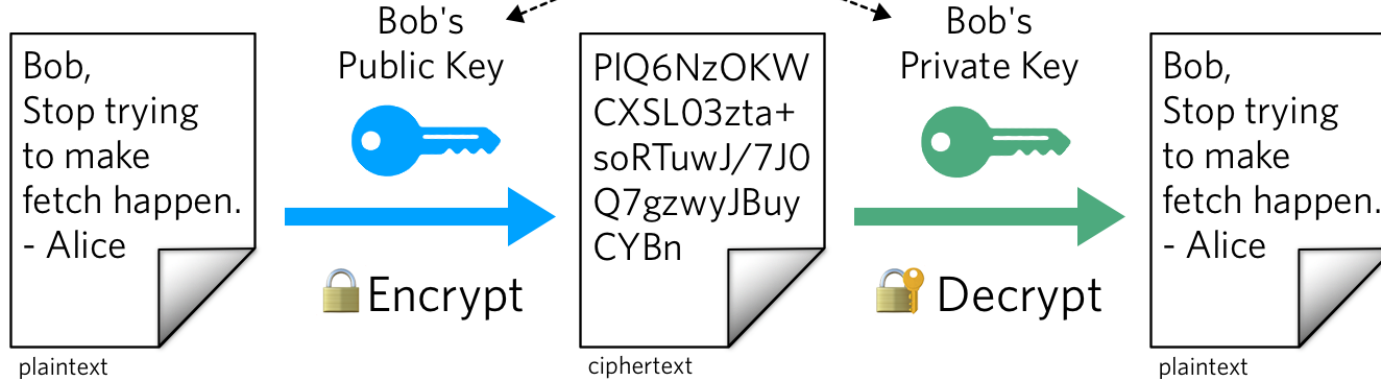


Chiffrement et signature

8

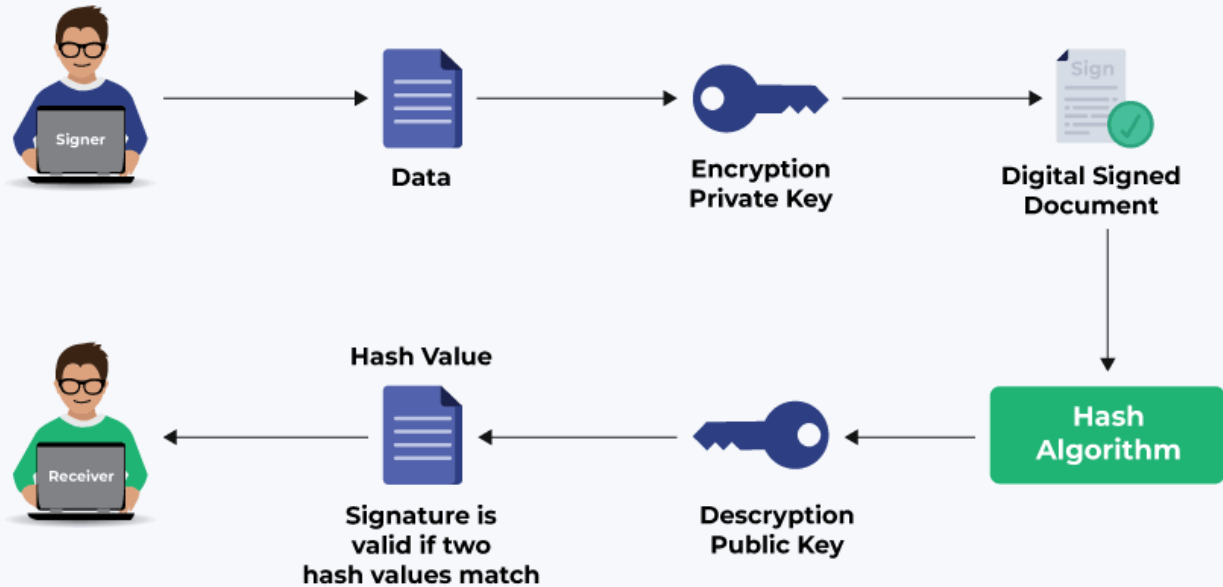
Public Key Cryptography

keys are different but
mathematically linked



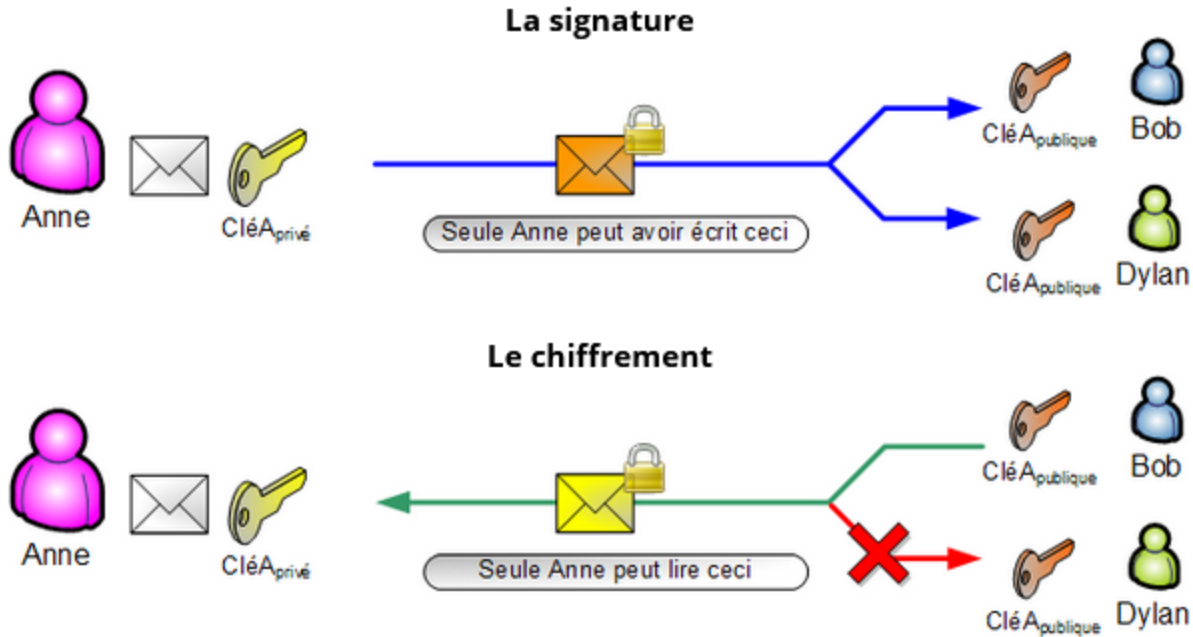
Chiffrement et signature

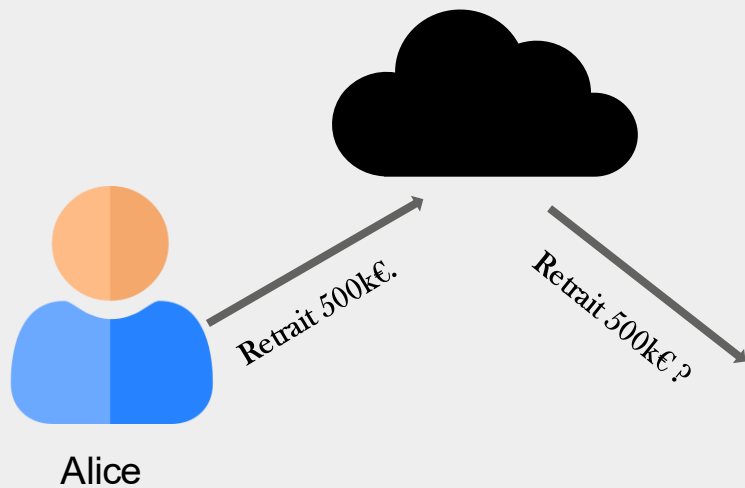
9



Chiffrement et signature

10



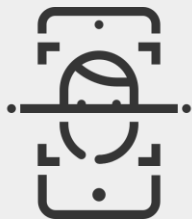


Qui etes vous?

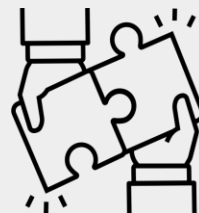
- Identifiant
- Mot de passe
- Adresse IP
- RIB



SIGNATURE NUMERIQUE



Authenticité



Intégrité



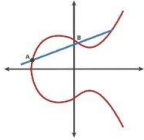
Non-Repudiation

Etat de l'art : une diversité d'algorithmes

13

ECDSA

Elliptic Curve Digital Signature Algorithm



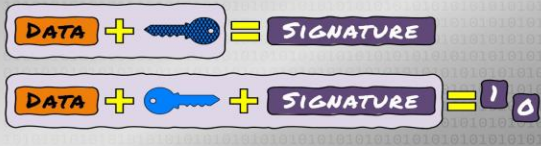
RSA

RIVEST
SHAMIR
ADELMAN



DSA

Digital Signature Algorithm



3DES

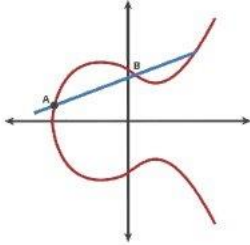


Les 2 algorithmes étudiés

14

ECDSA

Elliptic Curve Digital Signature Algorithm



RSA

RIVEST
SHAMIR
ADELMAN

Lequel choisir ?

15

RSA

Taille de clé 3072 bits (Lourd)
Complexité Grands entiers
Vitesse de calcul Lent
Utilisation Chiffrement et Signature

ECDSA

256 bits (plus léger)
Courbe elliptiques
Très rapide
Signature numérique

Nos objectifs SMART

16



Comprendre les
fondements
mathématiques de
la cryptographie
elliptique et du RSA

Implémenter les
protocoles RSA et
ECDSA pour
signer et vérifier
des transactions

Analyser les
performances
ECDSA vs RSA

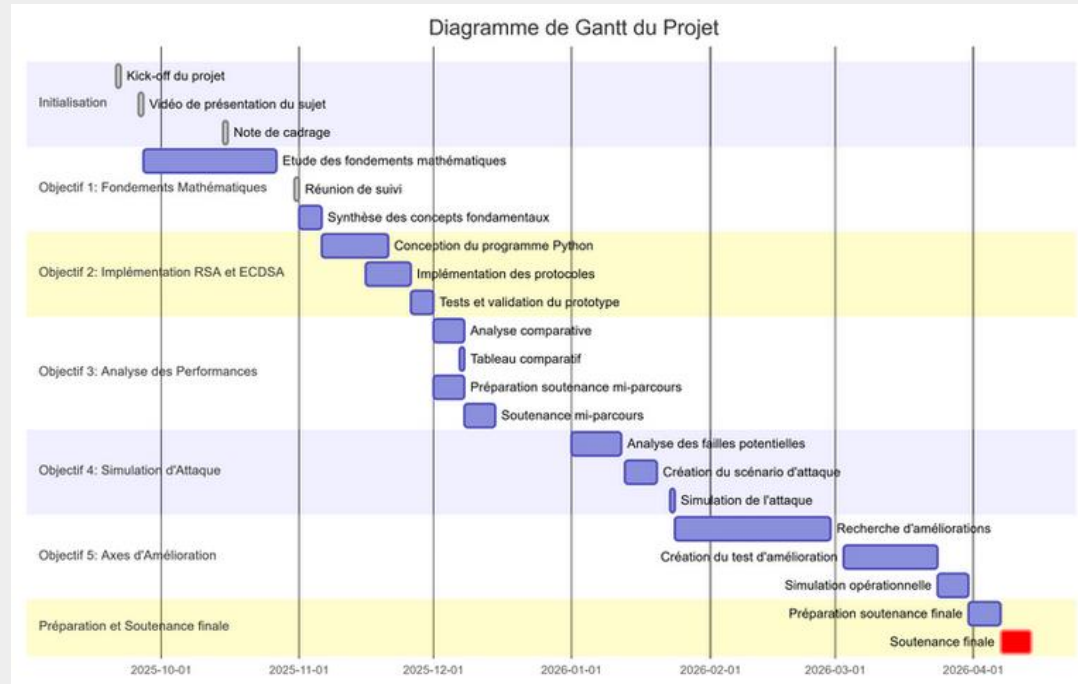
Simuler une
attaque sur une
mauvaise
implémentation

Trouver des axes
d'amélioration au
protocole ECDSA

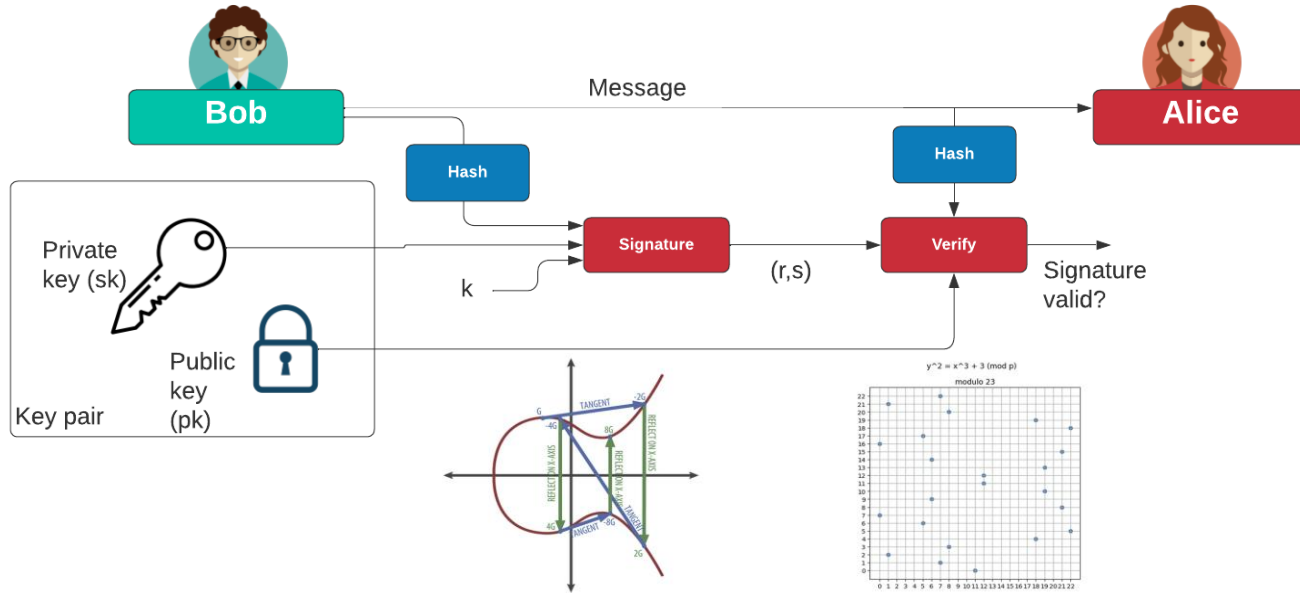


Notre organisation

17

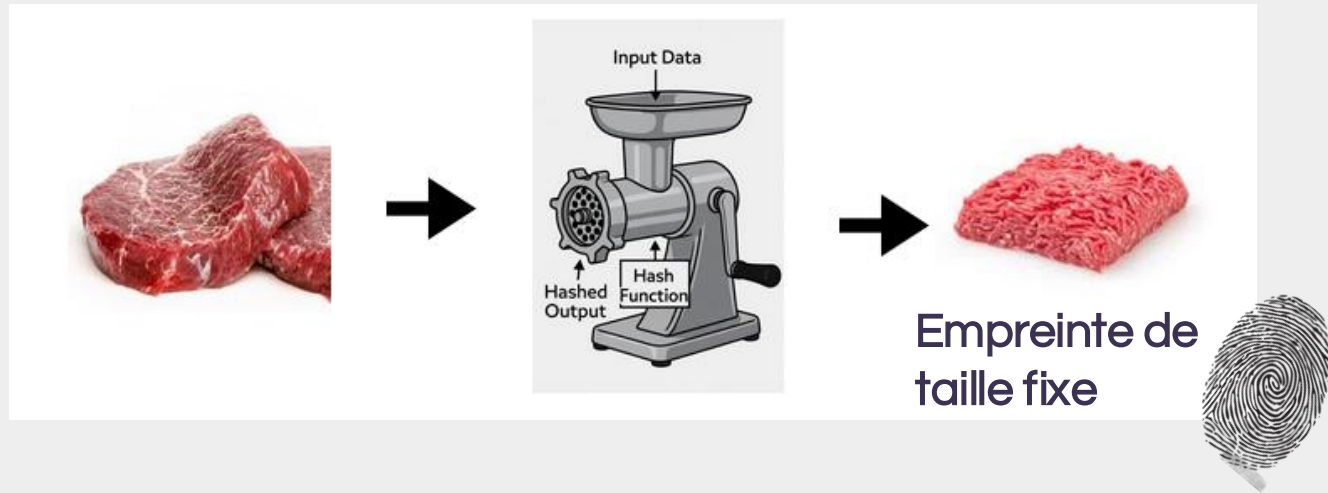


Comment fonctionne ECDSA ?

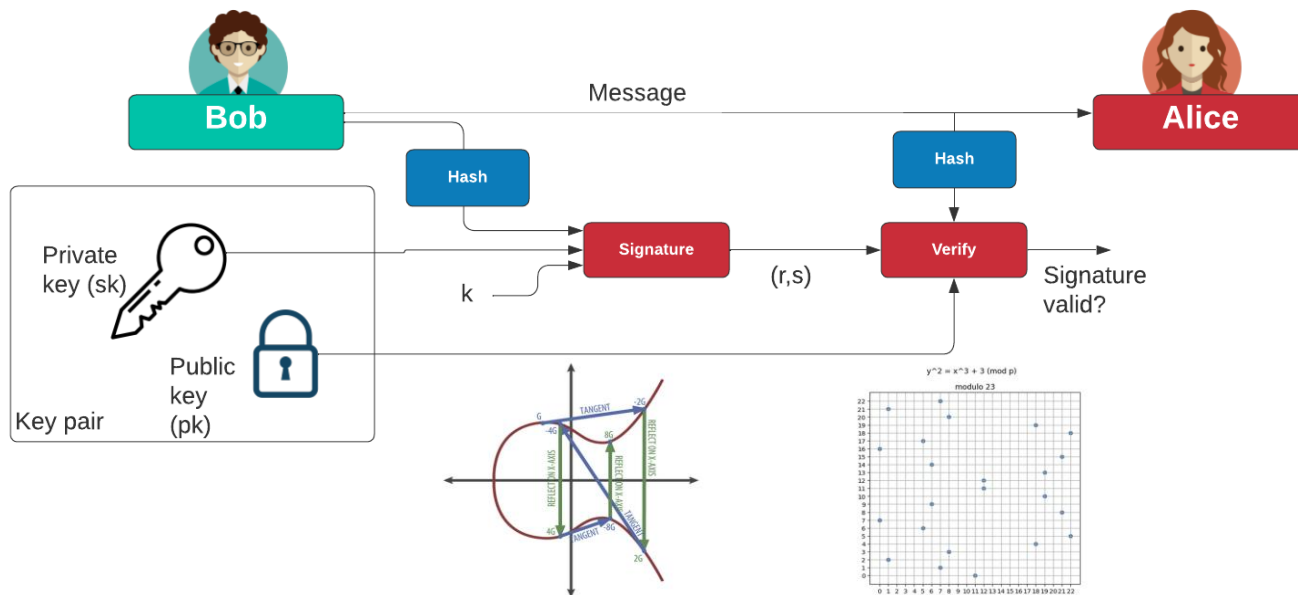


La fonction hash

19



Comment fonctionne ECDSA ?



Les limites d'ECDSA

21



Un standard dans le système bancaire ...



... mais pas **infaillible !**



Problème n°1 : Nonce (k) Reuse

Si deux nonces (k) sont identique, cela permet de **calculer la clé privée instantanément** par soustraction de signatures (comme pour la PS3).



Notre solution à ce problème : Nonce (k) Déterministe RFC 6979

Utiliser la clé privé pour generer le nonce via HMAC-SHA256.

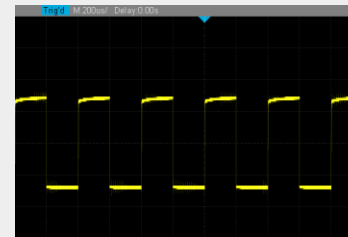
Source : RFC 6979 - Deterministic Usage of DSA and ECDSA

```
# ecdsa_hardened_run.txt
> Nonce RFC6979 stable: True
> Récupération clé via attaque:
> Result: False (Attack Blocked)
```



Problème n°2 : Fuites Side-Channel (SPA)

Le profil d'opérations varie selon les bits du secret,
révélant la clé aux **instruments de mesure**
(doublement pour les 0 et doublement + addition pour les 1).



Notre solution à ce problème : Montgomery Ladder & Blinding

- **Ladder** : Profil d'opérations fixe (On fait les 2 opérations mais on ne les applique pas tout le temps).
- **Scalar Blinding** : On cache le temps d'exécution en changeant la durée à chaque signature

Source : Coron - Resistance against DPA for ECC

```
# Analyse de trace (Op. counts)
> Leaky (Bit 0 vs 1): 382 vs 510
> Hardened (Fixe): 816
> Signal structurel réduit : True
```



Problème n°3 : Validation d'Entrées Insuffisante

Acceptation de signatures "Psychiques" (0,0) ou de clés publiques invalides provoquant des comportements indéfinis.



Notre solution à ce problème : Validation Stricte (SEC 1)

Contrôles systématiques avant calcul : $1 \leq r, s < n$ et validation que la clé publique est un point valide de l'ordre n .

Source : CVE-2022-21449 / Neil Madden - Psychic Signatures

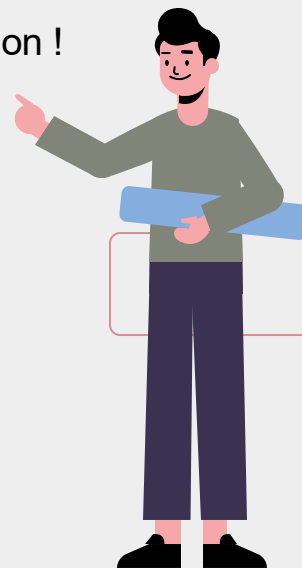
```
# Tests de robustesse
> Test signature (0,0): REJETÉ
> Test clé invalide: REJETÉ
> Test Point à l'infini: BLOQUÉ
```



Impact Performance vs Sécurité

Sécuriser oui, mais garder en tete la consomation et le temps d'execution !

Métrique (moyenne)	Classique	Hardened
Signature (s)	0.011s	0.020s
Vérification (s)	0.024s	0.039s
Overhead mesuré : ~1.7x		





Démonstration

Notre simulation de banque en ligne



Des questions ?

27

